Sovereign Vulnerability Proof Dossier Template (‘QF-SOVEREIGN-BOUNTY‘)

Submission Mode: Pseudonymous Security Researcher (Immunefi / Code4rena / Sherlock / Cantina / HackerOne)
Verification Engine: Local Airgapped QuantumFlex Stack (‘127.0.0.1:11434‘, ‘$0.00‘ Cloud Egress)
Citation & PoC Standard: ‘100.0%‘ SHA-256 Source-Bound Citations + Deterministic Reproducer

---

1. Vulnerability Summary & Severity Classification

- **Title:** ‘[Severity: High / Critical] <Component / Contract Name> ? <Concise Root-Cause Vulnerability>‘
- **Target Protocol / Repository:** ‘<Protocol Name & Git Commit SHA>‘
- **Affected Files & Lines:** ‘[<chunk_id>:p<page_or_line_offset>]‘
- **Vulnerability Class:**
- ‘[ ]‘ Single-Signer Escrow / Access-Control Bypass (‘CredTwoManAttestation‘ absent)
- ‘[ ]‘ ERC-20 / USDC 6-Decimal Precision Scaling Flaw (‘10^6‘ vs ‘10^18‘ mismatch)
- ‘[ ]‘ Missing Deterministic Idempotency / Replay Drain
- ‘[ ]‘ Runtime Descriptor / TOCTOU Race Condition (‘EXECUTED_FD != VERIFIED_FD‘)
- ‘[ ]‘ Post-Quantum / Cryptographic Key-Exchange Downgrade

---

2. Technical Root-Cause Analysis (Cryptographically Cited)

- **Primary Vulnerable State Transition (‘target_ma_crypto_inventory.pdf‘):** Treasury state mutations execute without hardware-enforced dual-control attestation, enabling a single compromised administrative signer to drain escrow balances in a single block ‘[target_ma_crypto_inventory_c0002_d6ca4c84:p2]‘.
- **Credential & Key Hygiene Exposure (‘target_ma_crypto_inventory.pdf‘):** Internal service authentication relies on legacy RSA-2048 certificates and static bearer credentials (‘[REDACTED_CREDENTIAL]‘), allowing lateral replay if an edge container is breached ‘[target_ma_crypto_inventory_c0001_a7951bbd:p1]‘.

---

3. Quantified Funds-at-Risk & Impact Assessment

- **Direct Economic Impact:** Up to ‘100%‘ of unthrottled treasury escrow balance due to absence of per-epoch velocity caps and dual-control hardware signatures.
- **Exploit Preconditions:** Compromised single hot-wallet or CI/CD signer key (zero multi-party hardware quorum required in current target implementation).

---

4. Deterministic Proof-of-Concept (Foundry / Python Reproducer)

‘‘‘solidity
// Run locally: forge test --match-test testExploitSingleSignerDrain -vvv

```
function testExploitSingleSignerDrain() public {
uint256 initialVaultBalance = 1_000_000 * 1e6; // 1,000,000 USDC (6 decimals)
assertEq(usdc.balanceOf(address(escrow)), initialVaultBalance);

// Single compromised signer drains vault without two-man hardware attestation
vm.prank(compromisedAdmin);
escrow.emergencySweep(attackerWallet, initialVaultBalance);

assertEq(usdc.balanceOf(address(escrow)), 0);
}
```

---

5. Recommended Fail-Closed Remediation

1. **Enforce Two-Person / Hardware Quorum:** Require two independent cryptographic signatures (or hardware-bound attestation) before any treasury state mutation.
2. **Enforce Deterministic Idempotency & Velocity Caps:** Derive transaction idempotency keys deterministically from proof block hashes (`sha256(blockHash)`) and cap per-epoch outflows.
3. **Strict 6-Decimal USDC Invariant:** Pin `1 USDC == 1_000_000` (`10^6`) across all settlement math and target `evm_version = "paris"`.

---

6. Deterministic Citation & Cryptographic Provenance Ledger (`AT-RDOS-02`)

Chunk ID	Source Artifact	Page / Offset	Verified Chunk SHA-256 Digest
`target_ma_crypto_inventory_c0002_d6ca4c84`	`filings/target_ma_crypto_inventory.pdf`	p. 2	`d6ca4c8408449b037843aaf775077e69fcf18d7227d0a340631fa158c3690d1e`
`target_ma_crypto_inventory_c0001_a7951bbd`	`filings/target_ma_crypto_inventory.pdf`	p. 1	`a7951bbde5bc672ac7a8278d09522ae7e6968d22f30b6e7d9ef0a389bc6ee53c`